UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

Universidad Politécnica de San Luis Potosí

Materia:

Seguridad Informática

Octavo Semestre

Profesor:

Servando López Contreras

Alumna:

América Fabiola Guerra Ramírez - 179884

Tarea: El eslabón más débil: diseño ético de una campaña de ingeniería social

Fecha de entrega: 6 de marzo de 2026

Contenido

El eslabón más débil: diseño ético de una campaña de ingeniería social 3

1. Marco teórico y fundamentación técnica 3
2. Tabla técnica comparativa de plataformas 4
3. Análisis individual de las plataformas..... 5
4. Análisis crítico comparativo 6
5. Conclusión 11

Referencias 12

El eslabón más débil: diseño ético de una campaña de ingeniería social

1. Marco teórico y fundamentación técnica

La ingeniería social es una técnica utilizada en el ámbito de la ciberseguridad mediante la cual los atacantes manipulan psicológicamente a las personas para obtener información confidencial o provocar acciones que comprometan la seguridad de sistemas y organizaciones. A diferencia de los ataques tradicionales que explotan vulnerabilidades técnicas, la ingeniería social se enfoca en el comportamiento humano, aprovechando factores como la confianza, la urgencia o la falta de conocimiento en seguridad digital.

El factor humano suele ser considerado el eslabón más débil dentro de la seguridad informática, ya que incluso los sistemas con controles tecnológicos fuertes pueden verse comprometidos si los usuarios proporcionan información sensible de manera involuntaria. Por esta razón, los ataques de ingeniería social representan una amenaza importante para organizaciones públicas y privadas.

Uno de los métodos más comunes de ingeniería social es el phishing, el cual consiste en el envío de mensajes fraudulentos que aparentan provenir de fuentes legítimas, como bancos, servicios digitales o departamentos internos de una empresa. Estos mensajes suelen contener enlaces o archivos maliciosos que buscan engañar al usuario para que proporcione credenciales, información financiera o datos personales.

Existen otros ataques de ingeniería social que buscan aumentar la efectividad del engaño. Por ejemplo, el spear phishing es un tipo de ataque dirigido a una persona o grupo específico dentro de una organización, donde el atacante investiga previamente a la víctima para hacer que el mensaje parezca más legítimo. También existen ataques como el vishing, que utiliza llamadas telefónicas para obtener información confidencial, y el smishing, que se realiza mediante mensajes de texto con enlaces maliciosos.

Las estrategias de ingeniería social se basan en principios psicológicos que influyen en la toma de decisiones de las personas. Entre los más utilizados se encuentran el principio de autoridad, donde el atacante se hace pasar por una figura confiable, y el sentido de urgencia, que busca que el usuario actúe rápidamente sin analizar el mensaje.

El impacto de la ingeniería social en la seguridad informática puede ser significativo, ya que un ataque exitoso puede permitir el acceso no autorizado a sistemas o el robo de información confidencial. Debido a que estos ataques explotan el comportamiento humano, su prevención requiere no solo medidas tecnológicas, sino también capacitación y concientización de los usuarios.

Para reducir estos riesgos, muchas organizaciones implementan programas de concientización en ciberseguridad y utilizan plataformas de simulación de phishing, que

permiten realizar campañas controladas para entrenar a los usuarios y evaluar su capacidad para identificar amenazas.

Estas simulaciones también permiten obtener métricas como la tasa de clics en enlaces maliciosos, el porcentaje de correos reportados y el nivel de riesgo humano dentro de la organización, lo que ayuda a mejorar los programas de capacitación.

Actualmente existen diversas plataformas profesionales para este tipo de entrenamiento, entre ellas Hoxhunt, Proofpoint, KnowBe4, Cofense, Phished, NINJIO, Mimecast e Infosec IQ, las cuales ofrecen simulaciones realistas, contenido educativo y herramientas de análisis del comportamiento de los usuarios para fortalecer la cultura de seguridad.

2. Tabla técnica comparativa de plataformas

Plataforma	Tipo de entrenamiento	Métricas de medición	Integración empresarial	Enfoque ético	Características destacadas
Hoxhunt	Aprendizaje gamificado basado en IA	Click rate, report rate, risk score	Microsoft 365, Google Workspace	Alta transparencia en simulaciones	Entrenamiento adaptativo con inteligencia artificial
Proofpoint	Simulación avanzada de phishing	Phish-prone percentage, response rate	Integración con sistemas de seguridad empresarial	Consentimiento organizacional previo	Análisis avanzado del comportamiento del usuario
KnowBe4	Plataforma completa de capacitación	Click rate, phishing susceptibility	Integración con SIEM y correo corporativo	Programas educativos preventivos	Gran biblioteca de contenido educativo
Cofense	Defensa contra phishing con reportes colaborativos	Tiempo de reporte, detección de amenazas	Integración SOC	Cultura de reporte y concientización	Análisis de incidentes en tiempo real
Phished	Entrenamiento	Risk score individual	Integración con herramient	Transparencia en campañas	Simulaciones adaptativas

	personalizado con IA		as de seguridad		
NINJIO	Capacitación mediante storytelling y videos	Participación en entrenamiento	Integración con LMS	Educación basada en narrativa	Contenido audiovisual interactivo
Mimecast	Seguridad del correo + simulaciones	Click rate y detección de amenazas	Integración con plataformas de correo	Protección preventiva	Seguridad de correo y concientización
Infosec IQ	Simulación de phishing y capacitación	Phish-prone percentage, report rate	Integración con Active Directory	Programas de aprendizaje continuo	Amplia biblioteca de simulaciones

3. Análisis individual de las plataformas

- **Hoxhunt** utiliza inteligencia artificial para ofrecer un entrenamiento adaptativo que evoluciona según el comportamiento del usuario. Su principal ventaja es el enfoque gamificado, donde los usuarios reciben retroalimentación inmediata al detectar correos sospechosos. Esto aumenta la participación y mejora el aprendizaje continuo.
- **Proofpoint** es una de las plataformas más utilizadas en empresas grandes. Permite realizar simulaciones avanzadas de phishing y analizar el comportamiento de los usuarios frente a ataques simulados. Su enfoque se centra en la gestión del riesgo humano mediante análisis de datos y métricas detalladas.
- **KnowBe4** es una de las plataformas más populares para programas de concientización en seguridad. Ofrece simulaciones de phishing, cursos interactivos, evaluaciones y reportes completos sobre el comportamiento de los usuarios frente a ataques.

- **Cofense** se enfoca en la detección colaborativa de phishing. Los usuarios pueden reportar correos sospechosos y el sistema analiza las amenazas en tiempo real. Esto permite que las organizaciones respondan rápidamente ante ataques reales.
- **Phished** utiliza inteligencia artificial para crear campañas personalizadas de phishing simulado. Analiza el comportamiento de los usuarios y ajusta los escenarios para mejorar el aprendizaje y la capacidad de detección.
- **NINJIO** utiliza videos educativos y narrativas para enseñar conceptos de seguridad. Aunque no se enfoca exclusivamente en simulaciones de phishing, es muy efectivo para programas de concientización.
- **Mimecast** combina protección de correo electrónico con capacitación de seguridad. Ofrece simulaciones de phishing y herramientas para analizar el comportamiento de los usuarios frente a amenazas.
- **Infosec IQ** es una plataforma de concientización en seguridad que incluye simulaciones de phishing, evaluaciones de riesgo y programas de capacitación continua para usuarios.

4. Análisis crítico comparativo

Las plataformas analizadas presentan enfoques diferentes en la gestión del riesgo humano dentro de la ciberseguridad.

Plataformas como KnowBe4 y Infosec IQ destacan por su enfoque educativo, ofreciendo amplias bibliotecas de contenido de capacitación y simulaciones de phishing para mejorar la conciencia de los usuarios.

Por otro lado, Hoxhunt y Phished incorporan inteligencia artificial para adaptar las simulaciones al comportamiento individual del usuario, lo que permite una capacitación más personalizada y efectiva.

Proofpoint y Cofense se orientan más hacia entornos corporativos avanzados, integrándose con centros de operaciones de seguridad (SOC) y sistemas de monitoreo de amenazas.

Finalmente, herramientas como Mimecast y NINJIO complementan la seguridad con enfoques educativos y de protección del correo electrónico.

En general, las plataformas más completas son aquellas que combinan simulación de phishing, capacitación continua, métricas de evaluación y retroalimentación inmediata, ya que permiten mejorar de manera progresiva la capacidad de los usuarios para identificar ataques de ingeniería social.

5. Fichas descriptivas de las plataformas

Hoxhunt

Tipo de plataforma: Simulación de phishing y entrenamiento en ciberseguridad basado en inteligencia artificial.

Funciones principales:

- Simulación automática de ataques de phishing.
- Entrenamiento adaptativo basado en el comportamiento del usuario.
- Retroalimentación inmediata cuando el usuario identifica correctamente un correo sospechoso.

Métricas utilizadas:

- Click rate (tasa de clics)
- Report rate (tasa de reporte)
- Risk score

Ventajas:

- Aprendizaje gamificado que motiva la participación de los usuarios.
- Simulaciones adaptativas que se ajustan al nivel de cada participante.

Enfoque ético:

Las simulaciones son utilizadas con fines educativos y no buscan recolectar credenciales reales.

Proofpoint

Tipo de plataforma: Plataforma empresarial de protección de correo electrónico y simulación de phishing.

Funciones principales:

- Simulación avanzada de ataques de phishing.
- Análisis del comportamiento del usuario frente a correos sospechosos.
- Integración con sistemas de seguridad empresarial.

Métricas utilizadas:

- Phish-prone percentage
- Click rate
- Response rate

Ventajas:

- Amplias capacidades de análisis del riesgo humano.
- Integración con sistemas de seguridad corporativa.

Enfoque ético:

Las simulaciones se realizan con consentimiento organizacional y con fines de capacitación.

KnowBe4

Tipo de plataforma: Plataforma de capacitación en seguridad y simulación de phishing.

Funciones principales:

- Simulación de correos de phishing.
- Cursos de concientización en ciberseguridad.
- Evaluaciones de seguridad para usuarios.

Métricas utilizadas:

- Phish-prone percentage
- Click rate
- Report rate

Ventajas:

- Amplia biblioteca de contenido educativo.
- Fácil implementación en organizaciones.

Enfoque ético:

Promueve la capacitación preventiva en lugar de la penalización de los usuarios.

Cofense

Tipo de plataforma: Plataforma de defensa contra phishing centrada en el reporte de usuarios.

Funciones principales:

- Sistema de reporte de correos sospechosos.
- Análisis colaborativo de amenazas.
- Simulaciones de phishing.

Métricas utilizadas:

- Tiempo de reporte
- Número de correos reportados
- Detección de amenazas

Ventajas:

- Fomenta la cultura de reporte dentro de las organizaciones.
- Permite responder rápidamente a ataques reales**.**

Enfoque ético:

Promueve la participación de los usuarios en la detección de amenazas.

Phished

Tipo de plataforma: Plataforma de entrenamiento adaptativo basada en inteligencia artificial.

Funciones principales:

- Simulaciones personalizadas de phishing.
- Análisis del comportamiento de los usuarios.
- Capacitación continua en seguridad.

Métricas utilizadas:

- Risk score individual
- Click rate
- Nivel de aprendizaje del usuario

Ventajas:

- Entrenamiento personalizado.
- Mejora progresiva del conocimiento en seguridad.

Enfoque ético:

Simulaciones educativas diseñadas para mejorar la capacidad de detección.

NINJIO

Tipo de plataforma: Plataforma educativa de concientización en ciberseguridad.

Funciones principales:

- Videos educativos sobre seguridad informática.
- Entrenamiento mediante storytelling.
- Programas de capacitación para empleados.

Métricas utilizadas:

- Participación en entrenamiento

- Nivel de aprendizaje

Ventajas:

- Contenido visual atractivo.
- Facilita la comprensión de conceptos de seguridad.

Enfoque ético:

Enfocado en la educación y concientización de los usuarios.

Mimecast

Tipo de plataforma: Plataforma de seguridad de correo electrónico con capacitación integrada.

Funciones principales:

- Protección contra phishing.
- Simulaciones de ataques.
- Análisis del comportamiento del usuario.

Métricas utilizadas:

- Click rate
- Report rate
- Nivel de riesgo del usuario

Ventajas:

- Integración con plataformas de correo corporativo.
- Protección preventiva contra amenazas.

Enfoque ético:

Utiliza simulaciones con fines educativos y preventivos.

Infosec IQ

Tipo de plataforma: Plataforma de capacitación y simulación de phishing.

Funciones principales:

- Simulaciones de phishing.
- Evaluaciones de seguridad.
- Programas de aprendizaje continuo.

Métricas utilizadas:

- Phish-prone percentage

- Click rate
- Report rate

Ventajas:

- Amplia biblioteca de simulaciones.
- Programas de capacitación estructurados.

Enfoque ético:

Capacitación enfocada en mejorar la cultura de seguridad.

6. Conclusión

La ingeniería social continúa siendo una de las amenazas más efectivas en el ámbito de la ciberseguridad, debido a que explota vulnerabilidades humanas más que fallas técnicas. Las plataformas de simulación de phishing representan una herramienta fundamental para reducir este riesgo mediante programas de concientización y entrenamiento práctico.

El análisis comparativo realizado demuestra que las soluciones actuales ofrecen diferentes enfoques, desde plataformas educativas hasta sistemas avanzados basados en inteligencia artificial. La elección de una herramienta adecuada depende de las necesidades de la organización, su infraestructura tecnológica y el nivel de madurez en ciberseguridad.

Implementar campañas de simulación de phishing de manera ética, transparente y educativa permite fortalecer la cultura de seguridad dentro de las organizaciones y reducir significativamente la probabilidad de que los usuarios caigan en ataques reales.

Referencias

Badman, A. (2025, 26 noviembre). Simulación de phishing. IBM. https://www.ibm.com/mx-es/think/topics/phishing-simulation

Beyond Security Awareness Training | KnowBe4 Human Risk MGMT Platform. (s. f.). https://www.knowbe4.com/

Enterprise Cybersecurity solutions, services & training | ProofPoint US. (s. f.). Proofpoint. https://www.proofpoint.com/

Ibm. (2025b, diciembre 4). Ingeniería social. IBM. https://www.ibm.com/mx-es/think/topics/social-engineering

Phishing Defense Powered by AI & Human Insight | Cofense. (s. f.). https://cofense.com/

Mimecast. (s. f.). Human risk management & advanced email security. Mimecast. https://www.mimecast.com/

NINJIO. (2026, 17 febrero). Cybersecurity Awareness Training & Human Risk Management | NINJIO. https://ninjio.com/

(S/f). Infosecinstitute.com. Recuperado el 6 de marzo de 2026, de https://www.infosecinstitute.com

The Hoxhunt Human Risk Management Platform. (s. f.). https://hoxhunt.com/